

SIMATS ENGINEERING

ASSESSMENT TOOL 02

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1410

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.

QUESTIONS: 01

Total Marks:100

Annexure A

VULNERABILITY ASSESSMENT REPORT

Code of Conduct:

I K Nitheesh Kumar 192325090 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: K Nitheesh Kumar

S.No	Assessment Criterion	Excellent	Good	Satisfactory	Needs Improvement	Marks
1	Incident Background and Technical Understanding(20)	Clearly explains the incident, timeline, affected organization, threat actor, wireless technology, and attack context.	Explains most incident details with minor omissions.	Provides a basic incident summary but lacks technical depth.	Incident description is inaccurate, incomplete, or unclear.	
2	Identification of Wireless Vulnerabilities(20)	Accurately identifies vulnerabilities related to wireless standards, encryption, authentication, access points, configuration, and network architecture.	Identifies most major vulnerabilities with reasonable explanation.	Identifies only basic or obvious vulnerabilities.	Fails to identify important vulnerabilities or provides incorrect findings.	
3	Risk, Impact, and Root-Cause Analysis(20)	Provides a detailed analysis of attack vectors, root causes, affected assets, likelihood, and operational, financial, privacy, legal, and reputational impacts.	Provides a good risk and impact analysis with minor gaps.	Discusses general risks and impacts without sufficient justification.	Risk analysis is weak, irrelevant, or unsupported.	
4	Security Recommendations and Mitigation Measures(20)	Proposes practical and well-justified controls involving secure authentication, encryption, segmentation, monitoring, access control, policies, and user awareness.	Recommends appropriate controls with minor omissions.	Provides basic recommendations with limited technical detail.	Recommendations are impractical, incomplete, or unrelated to the identified risks.	
5	Report Quality, Evidence, and Presentation(20)	Report is well-structured, professionally written, supported by reliable references, diagrams, tables, and a clear risk-rating summary.	Report is clear and organized with suitable evidence and references.	Report is understandable but lacks organization, evidence, or proper referencing.	Report is poorly organized, unsupported, or contains major presentation errors.	
					Total	

Annexure A

1. TJX Companies Wireless Network Breach, 2005–2007

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access. The incident demonstrated the risks of obsolete encryption, inadequate monitoring, weak network segmentation, and insecure transmission of sensitive data.

Assignment Question: Prepare a Vulnerability Assessment Report examining the wireless encryption, authentication, network segmentation, monitoring, and payment-data protection weaknesses that contributed to the TJX incident. Recommend how WPA2/WPA3, enterprise authentication, rogue-access-point detection, and PCI DSS controls could have reduced the risk.

2. Lowe's Wireless Network Intrusion, 2003

In 2003, attackers compromised the wireless network of a Lowe's retail store in Southfield, Michigan. The compromised wireless connection provided access to the company's central systems and other retail locations. The attackers attempted to install software intended to capture customers' credit-card information.

Assignment Question: Prepare a Vulnerability Assessment Report identifying the weaknesses that allowed a local wireless compromise to create access to a nationwide corporate network. Assess authentication, wireless isolation, firewall controls, point-of-sale segmentation, intrusion detection, and centralized access management.

3. Firesheep and Public Wi-Fi Session Hijacking, 2010

The Firesheep browser extension demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. The event highlighted the danger of websites encrypting only the login page while transmitting later session information without full HTTPS protection.

Assignment Question: Prepare a Vulnerability Assessment Report for a public Wi-Fi provider affected by Firesheep-style session hijacking. Assess open-network authentication, session-cookie protection, HTTPS enforcement, HSTS, VPN use, wireless client isolation, and user-security awareness.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

The DarkHotel campaign targeted business executives and government officials using compromised hotel networks. Selected guests connecting to hotel Wi-Fi were presented with fraudulent software-update prompts that delivered malware. The campaign demonstrated the risks associated with third-party Wi-Fi management, captive portals, insecure update mechanisms, and insufficient guest-network monitoring.

Assignment Question: Prepare a Vulnerability Assessment Report for the affected hotel environment. Examine guest authentication, captive-portal security, DNS integrity, network segmentation, third-party access, digital-signature verification, malware detection, and monitoring of privileged hotel-network systems.

5. Marriott Wi-Fi Deauthentication Incident, 2014

The United States Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using their personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident showed how unprotected wireless management frames could be misused to disconnect legitimate users.

Assignment Question: Prepare a Vulnerability Assessment Report analysing the misuse of IEEE 802.11 deauthentication frames. Discuss availability risks, wireless interference, Protected Management Frames, WPA3 requirements, wireless intrusion detection, acceptable-use policies, and legal consequences.

6. Fake Wi-Fi Networks at the Republican National Convention, 2016

During the 2016 Republican National Convention, a security experiment established fake open wireless networks near the event venue. Approximately 1,200 users connected within one day, and the experiment demonstrated how easily users could trust unknown network names and expose device or identity information.

Assignment Question: Prepare a Vulnerability Assessment Report evaluating the risks created by open Wi-Fi and fake access points at large public events. Assess SSID trust, automatic reconnection, captive-portal authentication, evil-twin detection, certificate validation, VPN enforcement, and participant-awareness controls.

7. Wi-Fi Attacks Against Anti-Doping Officials, 2016

According to a United States Department of Justice indictment, close-access teams targeted Wi-Fi networks used by anti-doping officials during events in Rio de Janeiro and Lausanne. Hotel Wi-Fi access was allegedly used to compromise credentials and obtain unauthorized access to sensitive anti-doping and medical information.

Assignment Question: Prepare a Vulnerability Assessment Report for an international sporting organization whose officials frequently use hotel and event Wi-Fi. Evaluate public-network authentication, credential protection, multifactor authentication, device certificates, endpoint security, VPN configuration, travel-security policies, and protection of medical information.

8. Attempted OPCW Wi-Fi Intrusion, 2018

In April 2018, Dutch authorities disrupted an attempted close-access cyber operation against the Organisation for the Prohibition of Chemical Weapons in The Hague. Equipment intended for a Wi-Fi compromise was found in a vehicle parked near the organization's premises.

Assignment Question: Prepare a Vulnerability Assessment Report for the OPCW wireless environment. Assess radio-frequency exposure outside the physical perimeter, enterprise Wi-Fi authentication, 802.1X, EAP certificate validation, rogue-device detection, wireless intrusion prevention, physical surveillance, and network-access control.

9. Australian Airport and In-Flight Evil-Twin Case, 2024

The Australian Federal Police charged a man who allegedly established fake free Wi-Fi access points that imitated legitimate networks at airports and other locations. The alleged purpose was to capture personal data from users who connected to the fraudulent access points.

Assignment Question: Prepare a Vulnerability Assessment Report for an airport or airline affected by an evil-twin access point. Analyse SSID impersonation, captive-portal authentication, automatic connection, certificate warnings, passenger-data exposure, rogue-access-point detection, staff response procedures, and user-verification methods.

10. Network Rail Public Wi-Fi Portal Compromise, 2024

On September 25, 2024, public Wi-Fi services at 19 major United Kingdom railway stations displayed unauthorized offensive content. Reports stated that the Wi-Fi landing page was changed using a legitimate administrator account. The affected services were suspended while the incident was investigated.

Assignment Question: Prepare a Vulnerability Assessment Report examining the authentication and access-control weaknesses that may allow misuse of a legitimate administrator account. Assess privileged-access management, multifactor authentication, captive-portal security, third-party supplier access, logging, change approval, account monitoring, and incident-response procedures.

CO4 – ASSESSMENT TOOL 02

Vulnerability Assessment Report

Course: Ethical Hacking | Course Code: ITA1410

Course Outcome: CO4 – Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux. 穀filecite學turn1file0學L5-L8係

Scope: This report answers the ten wireless-security incident case studies provided in Annexure A. The analysis preserves the terminology and focus areas specified in the assignment. Where the source does not provide a technical fact, the report identifies the recommended assessment/control rather than presenting an unsupported incident fact.

1. TJX Companies Wireless Network Breach, 2005–2007

1.1 Incident Background and Technical Understanding

The source states that TJX experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. It identifies WEP use during a transition toward WPA and inadequate controls to restrict wireless access as important weaknesses. The incident demonstrates the security risks associated with obsolete encryption, inadequate monitoring, weak network segmentation and insecure transmission of sensitive data. 穀filecite學turn1file0學L123-L128係

1.2 Vulnerability Assessment

Area	Assessment Finding	Risk
Wireless encryption	Use of WEP during the transition to WPA represented obsolete/weak protection.	High
Wireless access control	Wireless access was not adequately restricted.	High
Network segmentation	Weak segmentation could allow wireless compromise to reach sensitive retail/payment systems.	Critical
Monitoring	Inadequate monitoring reduced the ability to detect suspicious wireless activity.	High
Payment-data protection	Sensitive payment information required stronger isolation and protection.	Critical

1.3 Root Cause and Impact

The root causes indicated by the case are weak wireless cryptography, insufficient access restrictions, inadequate monitoring and weak network segmentation. The affected assets included retail network resources and payment-card information. Potential consequences include unauthorized access, payment-data exposure, financial loss, privacy harm, legal/regulatory consequences and reputational damage.

1.4 Recommendations and Mitigation

- Replace obsolete WEP with WPA2 or WPA3 as appropriate to the supported environment.

- Use enterprise authentication for corporate wireless access rather than shared credentials where feasible.
- Segment wireless clients from payment-card environments using firewalls, VLANs and least-privilege access.
- Deploy rogue-access-point detection and wireless monitoring.
- Apply PCI DSS controls to protect payment data and restrict access to the cardholder-data environment.
- Continuously monitor authentication, access and security events.

1.5 Risk Summary

Risk	Likelihood	Impact	Priority
Weak wireless encryption	High	High	Immediate
Insufficient wireless restriction	High	High	Immediate
Weak segmentation	Medium-High	Critical	Immediate
Insufficient monitoring	Medium	High	High

2. Lowe's Wireless Network Intrusion, 2003

2.1 Incident Background

The source states that attackers compromised the wireless network of a Lowe's retail store in Southfield, Michigan. The compromised wireless connection provided access to central systems and other retail locations, and attackers attempted to install software intended to capture customers' credit-card information. 穀filecite學turn1file0學L134-L138像

2.2 Vulnerability Assessment

Control Area	Weakness to Assess	Security Objective
Authentication	Insufficient wireless authentication or access restrictions.	Only authorized users/devices should connect.
Wireless isolation	Wireless access could reach broader corporate systems.	Contain wireless clients to an appropriate zone.
Firewall controls	Network boundaries did not sufficiently limit access.	Enforce deny-by-default segmentation.
POS segmentation	Payment systems required stronger isolation.	Prevent wireless compromise from reaching POS systems.
Intrusion detection	Detection capability needed strengthening.	Detect suspicious wireless/network behavior.
Centralized access management	Access should be centrally controlled and monitored.	Consistent identity, policy and auditability.

2.3 Risk and Root Cause

The central risk is that a local wireless compromise could become a pathway into central systems and other retail locations. The case therefore highlights the importance of separating local wireless connectivity from sensitive enterprise and point-of-sale networks. A failure at the wireless perimeter can have a much larger operational impact when network trust is excessive.

2.4 Recommendations

- Use strong enterprise wireless authentication and centrally managed identities.

- Place guest and wireless client traffic in isolated network segments.
- Use firewalls and access-control rules between wireless, corporate and POS networks.
- Apply strict least-privilege routing so wireless users cannot reach unrelated stores or central systems.
- Deploy wireless intrusion detection and centralized security monitoring.
- Regularly review network paths and validate segmentation with authorized security tests.

2.5 Risk Summary

Risk	Severity	Reason
Wireless-to-corporate access	Critical	Local compromise could expose broader systems.
Insufficient POS isolation	Critical	Payment systems are high-value targets.
Weak centralized access control	High	Inconsistent identities and permissions increase exposure.
Limited intrusion detection	High	Delayed detection increases attacker dwell time.

3. Firesheep and Public Wi-Fi Session Hijacking, 2010

3.1 Incident Background

The source explains that the Firesheep browser extension demonstrated how attackers on the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. It highlighted the danger of encrypting only the login page while later session information was transmitted without full HTTPS protection. 穀filecite學turn1file0學L143-L147像

3.2 Vulnerability Assessment

Area	Assessment	Risk
Open-network authentication	Open Wi-Fi permits nearby users to share the same network environment.	High
Session-cookie protection	Unencrypted cookies can expose authenticated sessions.	Critical
HTTPS enforcement	Partial HTTPS is insufficient for the complete authenticated session.	Critical
HSTS	Lack of HTTPS enforcement mechanisms can permit insecure connections.	High
VPN use	A VPN can provide an additional protected tunnel on untrusted networks.	Medium/High
Client isolation	Isolation can reduce direct client-to-client exposure.	High
User awareness	Users may not recognize risks of open networks.	Medium

3.3 Root Cause and Impact

The principal technical root cause described by the case is transmission of session information without full HTTPS protection. The resulting impact can include account impersonation, unauthorized access to authenticated sessions and exposure of user information. The incident also demonstrates why transport protection must cover the entire session rather than only the login transaction.

3.4 Recommendations

- Enforce HTTPS for every authenticated page and API request.
- Use HSTS to instruct supported browsers to use HTTPS.
- Protect session cookies with Secure and HttpOnly attributes and appropriate SameSite settings.
- Consider VPN use on untrusted public networks.
- Enable wireless client isolation where appropriate.
- Educate users to avoid transmitting sensitive information over unsecured networks and to heed certificate/security warnings.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

4.1 Incident Background

The source states that the DarkHotel campaign targeted business executives and government officials through compromised hotel networks. Selected guests received fraudulent software-update prompts that delivered malware. The case highlights third-party Wi-Fi management, captive portals, insecure update mechanisms and insufficient guest-network monitoring. 穀filecite學turn1file0學L150-L155像

4.2 Vulnerability Assessment

Area	Weakness to Assess	Risk
Guest authentication	Verify that guest identity and access are controlled appropriately.	High
Captive portal	Ensure portal traffic cannot be manipulated or used to deliver fraudulent content.	High
DNS integrity	Protect DNS from tampering or redirection.	High
Network segmentation	Separate guest traffic from hotel management systems.	Critical
Third-party access	Control suppliers and external administrators.	High
Software updates	Require trusted sources and signature validation.	Critical
Malware detection	Detect malicious downloads or endpoints.	High
Monitoring	Detect abnormal guest/privileged activity.	High

4.3 Root Cause and Impact

The case indicates that trust in hotel network infrastructure and update prompts can become an attack vector. Potential impact includes malware infection, credential theft, compromise of executive devices, exposure of confidential information and reputational damage.

4.4 Recommendations

- Isolate guest networks from privileged hotel-management systems.
- Use secure captive-portal architecture and protect DNS resolution.
- Limit third-party access using least privilege, strong authentication and logging.
- Require digital-signature verification for software updates.

- Deploy endpoint malware detection and network monitoring.
- Monitor privileged hotel-network systems separately from ordinary guest traffic.
- Establish incident-response procedures for suspected rogue infrastructure.

5. Marriott Wi-Fi Deauthentication Incident, 2014

5.1 Incident Background

The source states that the U.S. Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident demonstrated how unprotected wireless management frames could be misused to disconnect legitimate users.

5.2 Vulnerability Assessment

Area	Assessment Focus	Risk
Deauthentication frames	Management-frame protection should prevent unauthorized disruption where supported.	High
Availability	Forced disconnection can disrupt legitimate connectivity.	High
Wireless interference	Interference and unauthorized transmissions should be detected.	High
Protected Management Frames	PMF should be evaluated and enabled where appropriate.	High
WPA3	WPA3 capabilities and requirements should be considered.	High
Wireless IDS	Detect abnormal management-frame activity.	High
Acceptable-use policy	Clearly prohibit unauthorized interference.	Medium
Legal compliance	Wireless disruption can create regulatory/legal consequences.	High

5.3 Recommendations

- Enable Protected Management Frames (PMF) where supported and appropriate.
- Use modern wireless security such as WPA3 where compatible.
- Deploy wireless intrusion detection/prevention to identify abnormal deauthentication activity.
- Monitor RF conditions and investigate unexplained client disconnections.
- Document acceptable-use rules for wireless infrastructure.
- Train staff that intentional disruption of legitimate wireless communications is unacceptable.
- Maintain legal and regulatory compliance for wireless operation.

6. Fake Wi-Fi Networks at the Republican National Convention, 2016

6.1 Incident Background

The source describes a security experiment during the 2016 Republican National Convention in which fake open wireless networks were established near the venue. Approximately 1,200 users connected within one day, demonstrating how easily users could trust unknown network names and expose device or identity information. 穀filecite學turn1file0學L169-L173像

6.2 Vulnerability Assessment

Risk Area	Assessment
SSID trust	Users may assume a familiar-looking SSID is legitimate.
Automatic reconnection	Devices configured to auto-join can connect without deliberate verification.
Captive portal	Users may enter information into a fraudulent portal.
Evil-twin detection	Organizations need methods to identify unauthorized APs imitating legitimate networks.
Certificate validation	Users and applications should validate certificates and not ignore warnings.
VPN enforcement	Sensitive traffic should receive additional protection on untrusted networks.
Participant awareness	Security awareness should teach verification before connecting.

6.3 Impact

Potential impacts include exposure of device information, identity information and network traffic, depending on what services users access and what protections are applied. Large public events increase the number of potential targets and the likelihood that users will connect to unfamiliar networks.

6.4 Recommendations

- Provide clearly communicated official SSIDs and connection guidance.
- Disable unnecessary automatic Wi-Fi reconnection on managed devices.
- Deploy wireless monitoring to detect rogue or look-alike access points.
- Require users to validate security warnings rather than bypass them.
- Use VPN protection for sensitive activities on untrusted networks.
- Conduct awareness briefings before large public events.

7. Wi-Fi Attacks Against Anti-Doping Officials, 2016

7.1 Incident Background

The source states that, according to a U.S. Department of Justice indictment, close-access teams targeted Wi-Fi networks used by anti-doping officials during events in Rio de Janeiro and Lausanne. Hotel Wi-Fi access was allegedly used to compromise credentials and obtain unauthorized access to sensitive anti-doping and medical information. 穀filecite學turn1file0學L178-L182像

7.2 Vulnerability Assessment

Control	Assessment Requirement	Risk
Public-network authentication	Use secure authentication and avoid trusting open hotel networks.	High
Credential protection	Protect credentials from interception and phishing.	Critical
Multifactor authentication	Require a second factor for sensitive accounts.	High
Device certificates	Use managed device identity where appropriate.	High
Endpoint security	Ensure devices have current security controls.	High
VPN configuration	Use correctly configured VPN on untrusted networks.	High
Travel security	Apply special security procedures for international events.	High
Medical information	Apply strong confidentiality and access controls.	Critical

7.3 Root Cause and Impact

The case emphasizes the risk created when officials use hotel or event Wi-Fi while handling sensitive information. Credential compromise can become the bridge to unauthorized access. Medical and anti-doping information can create severe privacy, legal and reputational consequences if improperly disclosed.

7.4 Recommendations

- Require MFA for sensitive systems and administrator accounts.
- Use managed devices with endpoint protection and current patches.
- Deploy enterprise certificates for device/user authentication where appropriate.
- Use a trusted VPN configuration on hotel and event networks.
- Adopt travel-security policies for officials handling sensitive data.
- Minimize local storage of medical information and enforce strong access controls.
- Train officials to recognize rogue networks and credential phishing.

8. Attempted OPCW Wi-Fi Intrusion, 2018

8.1 Incident Background

The source states that in April 2018 Dutch authorities disrupted an attempted close-access cyber operation against the Organisation for the Prohibition of Chemical Weapons in The Hague. Equipment intended for a Wi-Fi compromise was found in a vehicle parked near the organization's premises. 穀filecite學turn1file0學L187-L190倖

8.2 Vulnerability Assessment

Area	Assessment Focus	Risk
RF exposure	Determine whether wireless signals extend beyond the intended physical perimeter.	High
Enterprise authentication	Use strong centrally managed wireless authentication.	High

802.1X	Enforce port-based network access control.	High
EAP certificate validation	Prevent users/devices from trusting fraudulent authentication infrastructure.	Critical
Rogue-device detection	Identify unauthorized APs and clients.	High
Wireless intrusion prevention	Contain or alert on malicious wireless activity.	High
Physical surveillance	Monitor the physical area around wireless-sensitive premises.	High
Network Access Control	Allow only compliant, authorized devices onto protected networks.	Critical

8.3 Recommendations

- Conduct authorized RF surveys to identify unintended wireless coverage.
- Use WPA2-Enterprise/WPA3-Enterprise with 802.1X as appropriate.
- Validate EAP server certificates to prevent credential interception through fraudulent infrastructure.
- Deploy wireless intrusion detection/prevention.
- Integrate rogue-device alerts with physical security response.
- Use Network Access Control to verify device posture and authorization.
- Review AP placement and transmit power to reduce unnecessary RF exposure.

9. Australian Airport and In-Flight Evil-Twin Case, 2024

9.1 Incident Background

The source states that the Australian Federal Police charged a man who allegedly established fake free Wi-Fi access points imitating legitimate networks at airports and other locations. The alleged purpose was to capture personal data from users connecting to the fraudulent access points.

9.2 Vulnerability Assessment

Area	Assessment Focus	Risk
SSID impersonation	Detect networks imitating official airport/airline SSIDs.	High
Captive portal	Prevent fraudulent portals from collecting passenger information.	High
Automatic connection	Reduce unintended connections to known-looking networks.	High
Certificate warnings	Train users to stop when certificate/security warnings occur.	High
Passenger-data exposure	Minimize sensitive information sent over untrusted networks.	Critical
Rogue-AP detection	Continuously identify unauthorized look-alike APs.	High
Staff response	Define procedures for detection, containment and communication.	High
User verification	Give passengers a simple way to verify the official network.	High

9.3 Recommendations

- Publish official SSID names and connection instructions through trusted channels.
- Use wireless monitoring to identify rogue access points.
- Separate public Wi-Fi infrastructure from operational airport/airline systems.
- Protect captive portals and minimize the personal data collected.
- Train staff to report suspected evil-twin networks immediately.
- Educate passengers to avoid bypassing certificate warnings and to verify the network name.
- Use VPN or other secure application-layer protections for sensitive activity.

10. Network Rail Public Wi-Fi Portal Compromise, 2024

10.1 Incident Background

The source states that on September 25, 2024, public Wi-Fi services at 19 major UK railway stations displayed unauthorized offensive content. Reports stated that the Wi-Fi landing page was changed using a legitimate administrator account, and the affected services were suspended while the incident was investigated. 穀filecite學turn1file0學L202-L206傢

10.2 Vulnerability Assessment

Area	Assessment Focus	Risk
Privileged-access management	Limit administrator privileges and separate duties.	Critical
MFA	Protect privileged accounts with <u>multifactor authentication</u> .	Critical
Captive-portal security	Secure the landing-page management interface.	High
Third-party supplier access	Control vendor accounts and <u>permissions</u> .	High
Logging	Maintain auditable administrator activity.	High
Change approval	Require controlled approval for portal changes.	High
Account monitoring	Detect unusual privileged logins or changes.	Critical
Incident response	Rapidly suspend/contain affected services and investigate.	High

10.3 Root Cause and Impact

The case specifically points to possible misuse of a legitimate administrator account. The assessment should therefore concentrate on privileged identity management, authentication, monitoring and change control rather than assuming that an external technical exploit occurred. Unauthorized content on public Wi-Fi portals can harm reputation, disrupt service and reduce user trust.

10.4 Recommendations

- Enforce MFA for all privileged and supplier accounts.
- Apply least privilege and separate administration of content, infrastructure and user management.
- Use privileged-access management for sensitive administrator sessions.

- Maintain immutable or protected logs of administrative activity.
- Require change approval and review for captive-portal content modifications.
- Monitor administrator logins for unusual location, timing or behavior.
- Maintain an incident-response plan for rapid portal isolation and service restoration.
- Regularly review and revoke unused third-party accounts.

Cross-Case Risk-Rating Summary

Case	Primary Wireless Risk	Overall Priority	Key Controls
TJX	Weak encryption, segmentation and payment-data protection	Critical	WPA2/WPA3, enterprise auth, segmentation, PCI DSS
Lowe's	Wireless compromise reaching enterprise/POS systems	Critical	Isolation, firewalling, centralized access control
Firesheep	Unencrypted session cookies on open Wi-Fi	Critical	Full HTTPS, HSTS, secure cookies, VPN
DarkHotel	Compromised hotel network and fraudulent updates	Critical	Segmentation, DNS security, signed updates, monitoring
Marriott	Misuse of deauthentication frames	High	PMF, WPA3, wireless IDS, policy
Fake Wi-Fi at RNC	Users trusting fake/open networks	High	Rogue-AP detection, VPN, awareness
Anti-Doping Officials	Credential and sensitive-information compromise	Critical	MFA, certificates, VPN, endpoint security
OPCW	Close-access Wi-Fi compromise	Critical	802.1X, EAP validation, WIPS, NAC, physical security
Australian Airport	Evil-twin SSID impersonation	High	Rogue detection, user verification, certificate validation
Network Rail	Legitimate administrator account misuse	Critical	PAM, MFA, logging, change control

Conclusion

The ten case studies collectively show that wireless security is not limited to encryption strength. Effective protection requires secure authentication, client and network isolation, strong transport protection, protected management frames, rogue-access-point detection, endpoint security, centralized monitoring, privileged-access controls, user awareness and clear policies. The recurring lesson is that a wireless compromise becomes significantly more damaging when the connected environment grants excessive trust or when sensitive information is not separately protected.

For an academic vulnerability assessment, every reported finding should be supported by the evidence available for the selected case, a clear risk rating, an explanation of affected assets and practical mitigation. The source assessment specifically evaluates incident understanding, identification of wireless vulnerabilities, risk/root-cause analysis, recommendations, and professional evidence/presentation. 穀filecite學turn1file0學L22-L39係 穀filecite學turn1file0學L40-L76係

Appendix A: Recommended Evidence for Submission

- Incident timeline and affected-organization summary from the case material.

- Wireless technology/encryption assessment table.
- Authentication and access-control analysis.
- Network segmentation diagram or logical description.
- Risk-rating table with likelihood and impact.
- Monitoring and detection control assessment.
- Security recommendations mapped to identified weaknesses.
- References to the supplied assessment case description.
- Diagrams/tables and clear formatting in the final report.

Appendix B: Security Control Checklist

Control	Purpose	Priority
WPA2/WPA3	Modern wireless encryption	High
Enterprise authentication / 802.1X	Centralized identity and access control	High
MFA	Protect privileged/sensitive accounts	High
Network segmentation	Contain wireless compromise	Critical
Protected Management Frames	Reduce management-frame abuse	High
Rogue AP detection	Identify evil-twin/unauthorized infrastructure	High
Wireless IDS/IPS	Detect and respond to wireless threats	High
VPN	Protect traffic on untrusted networks	Medium/High
Secure cookies + HTTPS	Protect sessions and application traffic	Critical
NAC	Restrict unauthorized devices	High
Privileged Access Management	Reduce administrator-account misuse	Critical
Logging and monitoring	Detect and investigate suspicious activity	High
User awareness	Reduce unsafe network connections	Medium